

期末考试复习知识点

基本概念，基本原理，基本方法

1. 基本概念

主题	要求掌握的概念
信息系统相关概念	1. 什么是信息系统
信息系统安全 的概念—— 怎样理解一个信息 系统是安全的？	1. 基于信息保障的理解，即突出系统的业务使命、全生命周期、管理、人员等理念，表现为： （1）业务的连续性，服务不能中断； （2）发现攻击的时间+做出响应的时间<黑客实现攻击的时间； （3）计算机犯罪取证。 2. 基于安全体系架构的理解，即架构设计必须合理，可满足功能和安全需求，包括： （1）信息系统的架构； （2）Oracle 数据库架构（例程，物理存储，逻辑存储等）。 3. 基于风险控制的理解，即把系统的风险控制到一个可以接受的范围之内。 4. 基于安全需求和安全策略的理解，即： （1）制定的安全策略（账户策略、安全策略、访问控制策略等）可以满足系统基本的安全需求（机密性、完整性、可用性、可记账性）； （2）所制定的安全策略（比如访问控制列表）可得到完全满足； （3）组策略及活动目录（包括对象、属性、Schema、域、域控制器、OU 等概念）。 5. 基于等级保护的理解，即系统达到相应等级的安全保护要求（基本要求和扩展要求），包括： （1）等级保护主要工作流程； （2）基本要求和扩展要求； （3）物理安全（含电磁泄露）； （4）操作系统安全。

	6. 基于可靠性的理解，即： （1）系统的寿命（MTTF 或者 MTBF）达到或者超过设计值； （2）系统的可用度达到或者超过设计值； （3）损坏硬盘的数据恢复能力达到或者超过设计值（RAID 或 Erasure Coding）； （4）系统的容错设计（硬件容错、软件容错、时间容错和信息容错）。
--	---

2. 基本原理

主题	要求掌握的原理
信息系统 概论	1. 针对“秒杀”及百万级并发等情况的架构设计，需要采用的关键技术； 2. 信息系统架构的复杂性问题是怎样产生的：结构复杂性和动态复杂性； 3. 如何度量信息系统的复杂度——两种方法：Halstead 和 McCabe。
信息系统 安全概论	1. 信息系统为什么是脆弱的？ 2. 攻防不对称性及应对思路，拟态主动防御 3. 信息系统安全保障模型：CMM 框架 4. Oracle 架构及其安全性分析。
安全需求和 安全策略	1. 访问控制列表（ACL）：标准 ACL，扩展 ACL 2. 常见的强制访问控制模型：Bell-LaPadula、BIBA 原理、优缺点及其改进 3. 安全策略如何应用到防火墙等安全设备中
信息系统的 风险评估	1. 风险评估流程
信息系统 等级保护	1. 定级的基本原则； 2. 备案地点
信息系统的 物理安全	1. 环境安全：机房的三度要求，常见的消防设计等 2. 电源防护措施 3. 电磁泄漏产生的原理、电磁泄漏的途径及防护方法
信息系统的 可靠性	1. 失效率的规律，失效率、寿命、可靠度三者之间关系的推导， $\lambda(t) = \frac{f(t)}{R(t)} = -\frac{R'(t)}{R(t)}$ 的推导 2. 可靠性模型：串联、并联模型或者其简单组合对应的寿命、可靠度推导

	3. 硬件可靠性和软件可靠性的不同 4. 软件的四中常见的可靠性模型及其主要思想 6. 冗余技术：时间冗余，信息冗余，硬件冗余，软件冗余，三模冗余（硬件冗余）原理及优缺点， 7. 软件冗余技术的 N-Version Programming 和 Recovery Block 的对比 8. RAID0/1/5/6 的原理及优缺点 9. Reed-Solomon 纠删码的基本原理及其在通信和大规模数据存储中的应用
计算机取证	1. 取证的范围 2. 取证过程应该遵循的原则
操作系统安全	1. 操作系统的一般性安全机制：隔离（四种隔离方式），访问控制，审计，加密； 2. 操作系统的隔离机制（包括物理隔离、逻辑隔离、时间隔离、加密隔离） 3. Kerberos 协议的原理； 4. 活动目录的逻辑结构和物理结构。
数据库安全	1. Oracle 数据库的三种结构：存储结构，进程结构，内存结构 2. 例程机制

3. 基本操作

主题	要求掌握的操作
信息系统安全概论	1. 可进行信息系统安全威胁分析； 2. 根据安全威胁分析安全需求； 3. 可根据需要编写标准 ACL 或扩展 ACL； 4. 可进行安全风险评估； 5. 可进行定级和备案。